iA Groupe financier

Politique corporative de sécurité de l'information

Avis de confidentialité

Ce document contient des informations privilégiées et confidentielles qui sont destinées à l'usage exclusif de iA Groupe financier.

Sous réserve d'une approbation d'un représentant dûment autorisé de iA Groupe financier, toute reproduction de ce document ou sa distribution à l'extérieur de son groupe autorisé d'utilisateurs est interdite.

Table des matières

1. Introduction 3

a. Objectifs de la Politique 3

b. Portée et application 3

c. Définitions 3

2. Principes 5

a. Culture et sensibilisation 5

b. Gouvernance et responsabilité 5

c. Gestion des risques liés à la Sécurité de l'information 6

d. Encadrements relatifs à la Sécurité de l'information 6

e. Protection de l'Information 6

f. Détection 7

g. Gestion des Incidents de sécurité de l'information 7

3. Principaux rôles et responsabilités 7

a. Conseil d'administration 7

b. Comité des risques, de gouvernance et d'éthique (CRGE) 7

c. Comité exécutif de gestion des risques (CEGR) 8

d. Haute direction 8

e. Chef de la gestion des risques (CRO) 8

f. Chef de la sécurité de l'information (CISO) 8

g. Chef des technologies de l'information (CIO) 9

h. Chef des données (CDO) 9

i. Chef de la protection des renseignements personnels (CPO) 9

j. Approvisionnement et ressources matérielles 9

k. Direction des Secteurs 9

l. Audit interne 10

m. Services juridiques 10

Politique corporative de sécurité de l'information	
Propriétaire	Vice-président exécutif et chef de la gestion des risques de iA Société financière inc.
Portée	Groupe
Instance d'approbation	Conseil d'administration sur recommandation du Comité des risques, de gouvernance et d'éthique
Date d'approbation initiale	24 janvier 2008
Date de révision	18 février 2025
Fréquence de révision	Tous les deux (2) ans ou lorsque des changements importants nécessitent une modification à la Politique
Prochaine révision	Février 2027

1. Introduction

a. Objectifs de la Politique

La *Politique corporative de sécurité de l'information* (la « **Politique** ») établit les principes qui sous-tendent l'encadrement de la Sécurité de l'information au sein de iA Groupe financier.

La Politique a pour objectifs de :

- Communiquer les attentes de la Haute direction concernant la Sécurité de l'information;
- Assurer la mise en œuvre d'une gouvernance définissant les rôles et responsabilités en matière de Sécurité de l'information; et
- Assurer la mise en œuvre d'encadrements afin de promouvoir une gestion saine et prudente des risques de Sécurité de l'information tout en favorisant l'atteinte des objectifs corporatifs.

b. Portée et application

La Politique s'applique à iA Société financière ainsi qu'à l'ensemble de ses Filiales.

Les termes au masculin dans la Politique incluent le féminin et n'ont pour objet que d'alléger le texte.

c. Définitions

« **Actif(s) informationnel(s)** » désigne tout système ou support d'information, technologie de l'information, installation ou un ensemble de ces éléments, acquis ou constitué par iA Groupe financier (c.-à-d. l'actif technologique ou l'actif TI) et toute Information, quel que soit le canal de communication ou son support, représentant de la valeur pour iA Groupe financier (c.-à-d. la donnée ou l'actif de donnée);

« **CDO** » désigne le chef des données pour iA Groupe financier;

« **CEGR** » désigne le Comité exécutif de gestion des risques de iA Société financière, lequel est le forum central chargé de superviser la gestion intégrée des risques de iA Groupe financier;

« **CIO** » désigne le chef des technologies de l'information pour iA Groupe financier;

« **CISO** » désigne le chef de la sécurité de l'information pour iA Groupe financier;

« **Confidentialité** » désigne la propriété selon laquelle l'information n'est pas accédée, diffusée ni divulguée à des personnes, des entités ou des processus non autorisés;

« **Contrôle(s) de sécurité** » désigne une mesure qui maintient ou atténue le risque. Les contrôles comprennent, sans s'y limiter, tout processus, politique, dispositif, pratique ou autres conditions ou actions qui maintiennent ou atténuent le risque;

« **Conseil d'administration** » désigne, selon le cas, le conseil d'administration de la Société ou un comité auquel le conseil d'administration a confié un volet particulier de ses rôles et responsabilités aux termes du mandat qui lui a été confié;

« **CPO** » désigne le chef de la protection des renseignements personnels pour iA Groupe financier;

« **CRGE** » désigne le comité des risques, de gouvernance et d'éthique de la Société qui est chargé de soutenir son Conseil d'administration dans ses responsabilités en matière de gouvernance, d'éthique et de gestion des risques;

« **CRO** » désigne le vice-président exécutif et chef de la gestion des risques de iA Société financière;

« **Direction** » désigne les employés qui occupent un rôle de gestion au sein d'un Secteur, dont notamment les directeurs, les vice-présidents et les vice-présidents exécutifs;

« **Disponibilité** » désigne la propriété d'être accessible et utilisable à la demande par une entité ou une personne autorisée;

« **Filiale(s)** » désigne une entité juridique contrôlée, directement ou indirectement, par iA Société financière;

« **Fournisseur** » désigne une personne physique ou morale qui fournit les biens ou les services nécessaires à la production ou au fonctionnement de iA Groupe financier;

« **GGRC** » désigne le Groupe gestion des risques et conformité de iA Société financière;

« **Haute direction** » désigne les membres du comité exécutif de iA Société financière;

« **iA Groupe financier** » désigne, collectivement, iA Société financière et ses Filiales;

« **iA Société financière** » désigne iA Société financière inc.;

« **Incident(s) de sécurité de l'information** » désigne une atteinte à la Disponibilité, à l'Intégrité ou à la Confidentialité des Actifs informationnels;

« **Information** » désigne une donnée ou un contenu contextualisé et organisé;

« **Intégrité** » désigne la propriété de protection contre la modification ou la destruction inappropriée de l'Information, y compris la garantie de la non-répudiation et de l'authenticité;

« **Propriétaire d'actif** » désigne un rôle organisationnel associé à un Actif informationnel. Pour les données, cette responsabilité est assignée à un responsable de données. Aux fins de la Politique, ce terme réfère autant aux propriétaires d'actifs TI qu'aux responsables de données;

« **Secteur(s)** » désigne une ou plusieurs unités organisationnelles commerciales ou unités organisationnelles de soutien au sein de iA Groupe financier pour lequel un vice-président exécutif de iA Société financière est responsable;

« **Sécurité de l'information** » désigne la protection de la Disponibilité, de l'Intégrité et de la Confidentialité de l'Information;

« **Société** » désigne, individuellement, iA Société financière ou l'une de ses Filiales.

2. Principes

La Politique définit des principes auxquels iA Groupe financier adhère afin d'assurer la Disponibilité, l'Intégrité et la Confidentialité de l'Information sous sa responsabilité. L'adhésion à ces principes vise à renforcer la posture et la culture de Sécurité de l'information de iA Groupe financier.

a. Culture et sensibilisation

iA Groupe financier est engagé à gérer de manière saine et proactive les risques liés à la Sécurité de l'information afin de protéger ses clients, ses partenaires et ses employés. La Haute direction est chargée d'assurer le leadership en la matière et de faire la promotion d'une culture de Sécurité de l'information au sein de iA Groupe financier.

La culture de Sécurité de l'information de iA Groupe financier doit favoriser l'adoption de comportements prudents et diligents par toute personne physique ou morale qui utilise ou accède aux Actifs informationnels de la Société en fonction de la sensibilité de l'Information en cause.

iA Groupe financier doit se doter d'un programme de sensibilisation et de formation continue sur la Sécurité de l'information, notamment en ce qui a trait à l'utilisation sécuritaire des Actifs informationnels et des déclarations des Incidents de sécurité de l'information.

b. Gouvernance et responsabilité

La Haute direction est chargée d'attribuer au sein de iA Groupe financier les responsabilités en matière de Sécurité de l'information. Celles-ci doivent assurer une séparation claire des tâches entre les différentes parties prenantes.

Elle voit à désigner un responsable de la sécurité de l'information (*Chief Information Security Officer)* pour iA Groupe financier. Le mandat du CISO, en complément de ce que prévoit la Politique, est défini par la Haute direction. Le CISO voit notamment à définir la stratégie de Sécurité de l'information et à surveiller sa mise en œuvre. La stratégie de Sécurité de l'information doit contribuer à soutenir l'atteinte des objectifs de iA Groupe financier. Le positionnement hiérarchique du CISO et les responsabilités qui lui sont assignées doivent favoriser son indépendance et son objectivité envers les activités de Sécurité de l'information qui incombent aux Secteurs. Le CISO exerce un rôle de supervision de ces activités de Sécurité de l'information.

Ce positionnement doit être soutenu par une gouvernance proposée par le CISO et approuvée par les instances appropriées qui définit les rôles et responsabilités des différentes parties prenantes en lien avec la gestion et la mise en œuvre de la Sécurité de l'information, en complément de ce que prévoit la Politique.

Dans le cadre du modèle des trois lignes de défense établi par la *Politique corporative de gestion intégrée des risques* de iA Société financière, en matière de Sécurité de l'information, ce positionnement du CISO se reflète par son rôle distinct (*ligne de défense 1B*) des Secteurs dans leurs activités quotidiennes (*ligne de défense 1A*) et de la deuxième ligne de défense.

La responsabilité en matière de Sécurité de l'information au sein d'iA Groupe financier est partagée entre les différentes parties prenantes en fonction de leurs rôles. Un Propriétaire d'actif doit être désigné pour

chaque Actif informationnel. La responsabilité liée à sa gestion, à son utilisation et à sa protection lui sont assignées.

c. Gestion des risques liés à la Sécurité de l'information

La gestion des risques liés à la Sécurité de l'information s'inscrit dans le cadre de gestion des risques de iA Groupe financier. La taxonomie des risques prend en compte les risques liés à la Disponibilité, à l'Intégrité et à la Confidentialité de l'Information.

Les principes établis à la *Politique corporative sur la gestion intégrée des risques* et à la *Politique corporative sur la gestion des risques opérationnels* s'appliquent. Les Secteurs dans leurs activités quotidiennes (*ligne de défense 1A*) sont les preneurs des risques. Les activités d'identification, d'évaluation et de gestion des risques (tel que définir la réponse au risque) liés à la Sécurité de l'information leurs incombent.

Un cadre interne de Contrôles de sécurité comprenant des contrôles clés qui prennent en considération les risques importants identifiés pour iA Groupe financier doit être défini, documenté dans les encadrements appropriés et mis en œuvre. Les Secteurs doivent s'assurer de mettre en œuvre les Contrôles de sécurité nécessaires en fonction de leurs risques dans le respect de la tolérance aux risques.

En matière de gestion des risques, le CISO exerce des fonctions d'encadrement et d'accompagnement (*ligne de défense 1B*) aux Secteurs mais il ne peut se substituer à ceux-ci. Ces fonctions incluent notamment la révision de plans d'action afin de confirmer aux preneurs des risques que les actions définies mitigent adéquatement les risques identifiés. Le CISO collabore étroitement avec le GGRC (*deuxième ligne de défense*) dans le cadre des activités de surveillance et de reddition de celui-ci en matière de risques liés à la Sécurité de l'information.

Les Contrôles de sécurité sont périodiquement soumis à différents types d'évaluations, de tests et de revues indépendantes afin de valider leur efficacité, en employant les mesures les plus appropriées en fonction notamment de la matérialité des risques qui y sont associés.

Un suivi régulier des risques permet d'atteindre et de maintenir un niveau de risque résiduel en fonction de l'appétit et de la tolérance établie pour iA Groupe financier. À cet égard, des rapports et indicateurs sont produits et suivis périodiquement, au niveau sectoriel ou consolidé.

d. Encadrements relatifs à la Sécurité de l'information

Des encadrements relatifs à la Sécurité de l'information sont documentés, tenus à jour et mis en œuvre à l'échelle de iA Groupe financier. Ces encadrements sont sous la responsabilité du CISO et il en assure leur développement et l'évolution en collaboration avec les parties prenantes concernées. Ils sont établis à partir de standards internationaux et des meilleures pratiques de l'industrie. Ils doivent prendre en compte les exigences légales et règlementaires applicables. La Politique et ces encadrements constituent le cadre normatif de Sécurité de l'information.

Les écarts aux encadrements relatifs à la Sécurité de l'information doivent être identifiés, documentés et suivis dans le cadre d'une approche basée sur le risque.

e. Protection de l'Information

Les Actifs informationnels sont protégés au moyen de Contrôles de sécurité proportionnels à leur valeur, notamment basé sur des critères de classification et de catégorisation. Les Contrôles de sécurité adressent tous les aspects liés à la Sécurité de l'information, internes et externes (ex. liés à un tiers), tels que ceux

en lien avec les systèmes et les applications informatiques, avec l'environnement physique et avec les individus.

En matière de systèmes et d'applications informatiques, les Contrôles de sécurité requis doivent notamment être identifiés dès la conception afin d'assurer une protection en amont de l'Information (*Security by Design*). Le Propriétaire d'actif à la responsabilité d'appliquer, de configurer et de maintenir les Contrôles de sécurité requis tout au long du cycle de vie de l'Actif informationnel afin de gérer adéquatement les risques de Sécurité de l'information qui y sont associés.

En matière de sécurité physique, des Contrôles de sécurité doivent notamment être mis en œuvre pour les immeubles permettant l'accès aux Actifs informationnels, autant ceux sous la responsabilité de la Société ou d'un tiers.

La Société doit mettre en place une saine gestion des identités et des accès. Les accès aux Actifs informationnels doivent être octroyés uniquement aux personnes autorisées en respect des principes du moindre privilège, du besoin de savoir et de la ségrégation des tâches.

f. Détection

Les événements liés à la Sécurité de l'information, les vulnérabilités des systèmes et des applications ainsi que les menaces émergentes sont gérées de manière proactive afin de prévenir la matérialisation des risques.

À cette fin, des processus d'investigation numérique, de gestion des menaces, de gestion des vulnérabilités et de surveillance et d'analyse de la sécurité sont définis et mise en œuvre au sein de la Société.

g. Gestion des Incidents de sécurité de l'information

Des encadrements, procédures et mécanismes sont mis en place entourant l'identification, la gestion des Incidents de sécurité de l'information et leur signalement en temps opportun aux parties prenantes internes et externes appropriés eu égard aux circonstances, notamment la Direction de la Société, les autorités règlementaires, les tiers et les clients (personnes physiques et morales) de la Société.

Ces encadrements, procédures et mécanismes doivent être clairs, notamment en matière de rôles et responsabilités, réactifs et axés sur le risque. Ils sont mis en œuvre pour contenir les impacts potentiels des Incidents de Sécurité de l'information et accélérer le retour aux opérations normales.

3. Principaux rôles et responsabilités

a. Conseil d'administration

i. Approuve la Politique ainsi que ses modifications, le cas échéant;
ii. Veille à l'affectation d'un responsable pour la surveillance du déploiement de la Politique et des encadrements relatifs à la Sécurité de l'information.

b. Comité des risques, de gouvernance et d'éthique (CRGE)

i. Révise et recommande la Politique ainsi que ses modifications, le cas échéant, pour approbation par le Conseil d'administration;
ii. Reçoit du CRO et examine une reddition de comptes périodiquement sur les risques et évènements significatifs de Sécurité de l'information.

c. Comité exécutif de gestion des risques (CEGR)

i. Révise et recommande la Politique ainsi que ses modifications au CRGE, le cas échéant, pour approbation par le conseil d'administration de iA Société financière;
ii. Reçoit du CRO et examine une reddition de comptes périodiquement sur les risques et évènements significatifs de Sécurité de l'information.

d. Haute direction

i. Fait la promotion d'une culture de la Sécurité de l'information et en assure la diffusion;
ii. Veille à l'intégration des principes de la Politique aux valeurs, objectifs stratégiques et décisions, de manière à promouvoir des comportements démontrant une réelle adhésion à la Sécurité de l'information;
iii. Désigne un responsable de la sécurité de l'information (CISO) et définit son mandat;
iv. Veille à ce que la Direction désigne des responsables pour l'ensemble des différents Actifs informationnels et risques de Sécurité de l'information;
v. Soutient les membres de la Direction pour développer leur leadership en matière de Sécurité de l'information, en lien avec leurs domaines de responsabilité;
vi. Veille à la disponibilité des structures, du soutien, des ressources et des processus pour la Sécurité de l'information.

e. Chef de la gestion des risques (CRO)

i. Élabore la Politique et surveille son déploiement au sein de iA Groupe financier;
ii. Surveille les risques liés à la Sécurité de l'information de manière indépendante et en étroite collaboration avec le CISO;
iii. Surveille la gestion et le signalement des Incidents de sécurité de l'information;
iv. Synthétise, vulgarise et communique efficacement l'information liée aux risques de Sécurité de l'information auprès de diverses instances;
v. Rend compte au CEGR et au CRGE des risques et des évènements significatifs en matière de Sécurité de l'information, conformément à la *Politique corporative de gestion intégrée des risques.*

f. Chef de la sécurité de l'information (CISO)

i. Définit la stratégie de Sécurité de l'information et surveille à sa mise en œuvre;
ii. Définit des objectifs de Sécurité de l'information clairs pour les systèmes, les services technologiques, les processus, les immeubles et les personnes;
iii. Développe des encadrements relatifs à la Sécurité de l'information, incluant un cadre interne de Contrôles de sécurité, surveille leur déploiement au sein de iA Groupe financier et suit les écarts à ceux-ci dans le cadre d'une approche basée sur le risque;
iv. Valide l'efficacité de Contrôles de sécurité déployés pour les Actifs informationnels en employant les mesures les plus appropriées en fonction notamment de la matérialité des risques qui y sont associés;
v. Élabore et met en œuvre un programme de sensibilisation et de formation sur la Sécurité de l'information en collaboration avec les parties prenantes concernées;
vi. En fonction des encadrements et processus en vigueur, supervise ou participe à la réponse aux Incidents de sécurité de l'information avec les parties prenantes concernées;
vii. Soutient les Secteurs dans la gestion de leurs risques de Sécurité de l'information;

viii. Rend compte au CRO en matière de risques, d'évènements significatifs et de la posture de Sécurité de l'information;
ix. Soutient le CRO dans l'application de la Politique.

g. Chef des technologies de l'information (CIO)

i. S'assure que la Sécurité de l'information est bien prise en compte dans la planification, les orientations, les encadrements en matière d'architecture d'entreprise et d'utilisation des systèmes et des applications informatiques et que ceux-ci sont effectivement mis en œuvre dans les Secteurs en fonction des risques;
ii. Déploie les Contrôles de sécurité dont il a la responsabilité et en assure l'efficacité;
iii. S'assure que la capacité pour se préparer, détecter et répondre aux Incidents de sécurité de l'information de nature technologique est appropriée;
iv. Soutient les Secteurs dans la gestion de leurs risques de Sécurité de l'information pour la composante Disponibilité associée aux Actifs informationnels;
v. Rend compte au CRO en matière de risques et d'évènements significatifs de Sécurité de l'information pour la composante Disponibilité associée aux Actifs informationnels;
vi. Soutient le CRO dans l'application de la Politique.

h. Chef des données (CDO)

i. S'assure que la Sécurité de l'information est bien prise en compte dans les encadrements en matière de données sous sa responsabilité et que ceux-ci sont effectivement mis en œuvre dans les Secteurs;
ii. Soutien le CISO dans l'élaboration des encadrements liés à la protection des données sous sa responsabilité.

i. Chef de la protection des renseignements personnels (CPO)

i. Valide que les encadrements en matière de Sécurité de l'information sont suffisamment robustes pour permettre à iA Groupe financier de respecter ses obligations en lien avec la protection des renseignements personnels;
ii. S'assure que les encadrements en matière de protection des renseignements personnels sont arrimés avec ceux en matière de Sécurité de l'information.

j. Approvisionnement et ressources matérielles

i. Déploie les Contrôles de sécurité physique dont il a la responsabilité et en assure l'efficacité;
ii. S'assure que les exigences de Sécurité de l'information établies aux encadrements en matière de Sécurité de l'information sont intégrées et prises en compte dans le processus d'approvisionnement et dans les relations avec les Fournisseurs en fonction du niveau de risque.

k. Direction des Secteurs[1]

i. Appuie l'engagement de la Société vis-à-vis de la Sécurité de l'information;

[1] Cette fonction comprend le rôle de Propriétaires d'actifs.

ii. Désigne et soutient les Propriétaires d'actifs au sein de leur Secteur;
iii. Met en œuvre les Contrôles de sécurité adéquats relevant de leur responsabilité en fonction du niveau de risque afin de respecter les encadrements relatifs à la Sécurité de l'information;
iv. Identifie et documente les écarts aux encadrements relatifs à la Sécurité de l'information applicables à leurs activités et à leurs Actifs informationnels et en informe le CISO;
v. Identifie, évalue et gère les risques de Sécurité de l'information dans les opérations quotidiennes de leur Secteur, notamment ceux liés aux Actifs informationnels sous leur responsabilité;
vi. Établit et réalise les plans d'action adéquats liés aux risques de Sécurité de l'information et maintient à jour leur statut;
vii. Fait rapport au CISO périodiquement, et au besoin en temps réel, des risques et des évènements liés à la Sécurité de l'information;
viii. Rend compte au CRO en matière de risques en dépassement de tolérance et d'évènements significatifs au sein de leur Secteur;
ix. Rapporte via le canal approprié tout Incident de sécurité de l'information selon les procédures et mécanismes en vigueur;
x. S'assure que les employés de leur Secteur ont recours aux services de sécurité qui leur sont offerts et qu'ils sont sensibilisés et formés à la Sécurité de l'information.

l. Audit interne

i. Fourni une assurance et des conseils indépendants et objectifs sur la conformité, l'adéquation et l'efficacité des contrôles de la gouvernance et de la gestion, ainsi que de la gestion des risques de la Sécurité de l'information, afin de contribuer à la réalisation des objectifs de iA Groupe financier et de promouvoir et favoriser l'amélioration continue.

m. Services juridiques

i. Conseillent les parties prenantes et les Secteurs relativement à leurs obligations légales et réglementaires en matière de Sécurité de l'information;

ii. Assurent la veille législative et règlementaire en lien avec la Sécurité de l'information, incluant le suivi, l'interprétation et la communication des changements législatifs et réglementaires aux parties prenantes.